

Day 5: Authentication & Access Control (Detailed Notes)

1. Core Security Concepts & Metrics

Authentication

Authentication means **proving who you are**.

Think about entering your university.

- Student ID proves your identity.
- Password proves your identity online.

Example

You enter Gmail.

- Username: john@gmail.com
- Password: *****

Google checks if the password belongs to John.

If yes → Authentication successful.

Access Control

After authentication, the system decides **what you are allowed to do**.

Example

Three users log into the same hospital system.

User	Can View Records	Can Edit	Can Delete
Doctor	☐	☐	×

User	Can View Records	Can Edit	Can Delete
Nurse	☐	☒	☒
Administrator	☐	☐	☐

Everyone logs in successfully.

But each gets different permissions.

That is **Access Control**.

Why are Credentials Important?

Microsoft and Verizon reports show:

81% of hacking-related breaches happen because attackers steal usernames and passwords.

Example

Employee uses

Password123

Attacker guesses it.

The attacker now logs in like the real employee.

No hacking required.

MFA Blocks 99.9%

Even if an attacker steals your password...

They still need the second factor.

Example

Attacker knows:

Username
Password

But your phone asks:

Approve Login?

Attacker cannot approve.

Attack fails.

Blast Radius

Blast Radius means

How much damage can an attacker cause after getting inside?

Imagine a fire.

Small fire → one room burns.

Large fire → entire building burns.

Same idea in cybersecurity.

Example

Employee account only accesses Payroll.

If hacked:

Only payroll affected.

Administrator account hacked:

Entire company affected.

Least Privilege reduces blast radius.

Front Door Analogy

Imagine a bank.

Vault = Encryption

Front Door = Authentication

Rooms = Access Control

You first enter the building.

Then security decides which rooms you may enter.

Exam Tip

Authentication $\neq$ Authorization

Authentication = Identity

Authorization = Permission

2. AAA Framework

AAA stands for

Authentication
Authorization
Accounting

Always remember the order.

Authentication (Who are you?)

Checks identity.

Examples

- Password
- Fingerprint
- Smart Card
- Face ID

Example

Login:

Username: Sarah

Password: abc123

System verifies Sarah.

Done.

Authorization (What can you do?)

After login.

Example

Sarah is HR Manager.

She can

☐ View employee salaries

Normal employee

× Cannot.

Accounting

Tracks everything.

Questions answered:

Who logged in?

When?

From where?

What files changed?

Example Log

```
User:
John

Time:
9:15 AM

IP:
192.168.1.5

Action:
Deleted Report.pdf
```

Accounting is extremely important for investigations.

Easy Way to Remember AAA

Authentication

↓

Authorization

↓

Accounting

Think:

```
Identify
```

```
↓
```

Allow



Record

3. Three Authentication Factors

Authentication factors are divided into three categories.

Factor 1

Something You KNOW

Examples

Password

PIN

Security Question

Passphrase

Example

ATM PIN

2489

Only you know it.

Advantages

Easy

Cheap

No hardware

Disadvantages

Can forget

Can guess

Can steal

Can phish

Factor 2

Something You HAVE

Examples

Phone

YubiKey

Smart Card

Authenticator App

RSA Token

Example

Bank sends code to your phone.

Only your phone receives it.

Advantages

Harder to steal remotely.

Disadvantages

Can lose device.

Factor 3

Something You ARE

Biometrics

Examples

Fingerprint

Face

Iris

Voice

Example

Unlock iPhone using Face ID.

Advantages

Never forget.

Disadvantages

Cannot change.

If fingerprint database leaks...

You cannot get a new fingerprint.

What is MFA?

MFA means

Use two or more DIFFERENT factor categories.

Correct MFA

Password

Fingerprint

(Type 1 + Type 3)

Password

Authenticator App

(Type 1 + Type 2)

NOT MFA

Password

Security Question

Both are

Something You Know.

So it is still one factor.

Exam Question

Is Password + PIN MFA?

Answer:

× No

Both are Something You Know.

4. Password Security

Why Length Matters

Suppose:

Password A

Dog12

5 characters.

Easy.

Password B

MyDogLikesPizza2026!

20 characters.

Much harder.

Length creates exponentially more possibilities.

Password vs Passphrase

Bad

P@ss123

Good

MyDogAte7PizzaSlices!

Long.

Easy to remember.

Hard to crack.

NIST Recommendations

Modern password guidance recommends:

- Use long passphrases instead of forcing complex symbols.
 - Do **not** require frequent password changes unless there is evidence of compromise.
 - Check new passwords against databases of known breached passwords.
 - Allow copy/paste so password managers work well.
-

Password Managers

Examples

- **Bitwarden**
- **1Password**
- **Dashlane**

Purpose

Generate random passwords.

Store them securely.

Example

Instead of remembering

Google

Netflix

Amazon

Bank

Facebook

You remember only ONE master password.

5. MFA Methods

Strongest → Weakest

1. Hardware Security Keys

Example

YubiKey

Google Titan

You insert USB.

Touch button.

Done.

Very resistant to phishing because the key verifies the real website before authenticating.

2. Authenticator Apps

Example

Google Authenticator

Microsoft Authenticator

Every 30 seconds

Code changes.

Example

624981

After 30 seconds

312955

3. Push Notifications

Phone shows

Approve Login?

Press

Approve

or

Deny

Easy.

Problem

Attackers spam notifications.

Eventually user presses Approve.

Called

MFA Fatigue.

4. SMS

Bank sends

839211

Problem

SIM swapping.

5. Email Codes

Weakest.

If attacker hacks email...

They receive the MFA code too.

MFA Attacks

SIM Swapping

Attacker tricks mobile company.

Phone number transferred.

Now attacker receives your SMS codes.

MFA Fatigue

Attacker sends

Approve?

Approve?

Approve?

Approve?

50 times.

User becomes annoyed.

Clicks Approve.

Attack succeeds.

Real-Time Phishing (Man-in-the-Middle)

Victim visits a fake login page.

Enters password and MFA code.

Attacker immediately forwards them to the real website and captures the authenticated session.

6. Single Sign-On (SSO)

Login once.

Use many apps.

Example

Login to your university account once.

Then open:

- Email
- Moodle
- Library
- Student Portal

No second login.

Identity Provider (IdP)

The service that verifies your identity.

Examples

- Microsoft Entra ID
 - Okta
 - Google
-

Service Provider (SP)

Applications that trust the IdP.

Examples

- Slack
 - Salesforce
 - AWS
-

SSO Risk

One account compromised

↓

Everything compromised.

Therefore

Strong MFA is essential.

7. Access Control Models

DAC

Owner decides.

Example

Google Drive.

Owner shares file.

Owner removes access.

Flexible but permissions can become inconsistent.

MAC

System decides.

Military.

Top Secret.

Secret.

Confidential.

You cannot override it.

RBAC

Role decides.

Examples

Doctor

Nurse

Receptionist

Easy to manage because users inherit permissions from their role.

ABAC

Uses attributes.

Example Policy

```
Department = Finance
```

```
AND
```

```
Office = Addis Ababa
```

```
AND
```

```
Time = 9AM-5PM
```

```
Allow Access
```

If any condition fails

Access denied.

Easy Memory Trick

DAC

Owner decides

MAC

Government/System decides

RBAC

Role decides

ABAC

Attributes decide

8. Principle of Least Privilege (PoLP)

Only give users what they need.

Nothing more.

Example

Receptionist

Needs

Appointments

Patient Names

Does NOT need

Payroll

Server Settings

Admin Password

Privilege Creep

Employee promoted.

Gets new permissions.

Old permissions never removed.

After years

They have too much access.

Solution

Quarterly access reviews.

JIT

Just-In-Time

Temporary admin rights.

Example

Administrator access

Only

4 hours.

Then automatically removed.

JEA

Just Enough Access

Instead of full administrator,

Allow

Restart Service

Only.

Separation of Duties (SoD)

One person cannot complete a critical process alone.

Example

Employee A

Creates payment.

Employee B

Approves payment.

Reduces fraud.

9. Zero Trust

Old Model

Outside

Not trusted

↓

Firewall

↓

Inside

Trusted

Modern attacks show this assumption is unsafe.

New Model

Never Trust.

Always Verify.

Even inside the company network.

Three Principles

Verify Explicitly

Always check

Identity

Device

Location

Behavior

Least Privilege

Give minimum permissions.

Assume Breach

Assume attackers are already inside.

Protect every system independently using techniques like micro-segmentation and continuous monitoring.

10. Biometrics

Examples

Fingerprint

Face

Voice

Iris

Behavior

Physical Biometrics

Fingerprint

Face

Retina

Iris

Behavioral Biometrics

Typing Speed

Mouse Movement

Walking Pattern

These can support continuous authentication.

FAR

False Acceptance Rate

Bad person accepted.

Security problem.

Example

Attacker scans fake fingerprint.

Door opens.

High FAR = Bad security.

FRR

False Rejection Rate

Real user rejected.

Usability problem.

Example

Owner scans fingerprint.

Door refuses.

High FRR = Frustrating for users.

Liveness Detection

Stops fake biometrics.

Checks

Eye blink

Pulse

3D Face

Temperature

Without liveness detection,

A printed photo or mask might fool the system.

Quick Exam Memory Table

Concept	Easy Question	Easy Answer
Authentication	Who are you?	Verify identity
Authorization	What can you do?	Permissions
Accounting	What did you do?	Logging

Concept	Easy Question	Easy Answer
MFA	Two different factors	Password + phone
DAC	Who decides?	Owner
MAC	Who decides?	System
RBAC	Based on?	Role
ABAC	Based on?	Attributes
PoLP	Main idea	Minimum permissions
JIT	Admin rights	Temporary
JEA	Access	Only required actions
SoD	Critical task	Two people share responsibility
FAR	Wrongly accepts attacker	Security issue
FRR	Rejects real user	Usability issue
Zero Trust	Main rule	Never Trust, Always Verify

Most Important Exam Questions

1. Authentication vs Authorization

- Authentication = Verify identity.
- Authorization = Decide permissions.

2. What does AAA stand for?

- Authentication, Authorization, Accounting.

3. Is Password + PIN MFA?

- **No**, both are "Something You Know."

4. Which MFA method is strongest?

- Hardware security keys (e.g., YubiKey).

5. Which access control model is most common in companies?

- RBAC (Role-Based Access Control).

6. What is the Principle of Least Privilege?

- Give users only the minimum permissions required.

7. What are the three Zero Trust principles?

- Verify Explicitly, Use Least Privilege, Assume Breach.

8. What is the difference between FAR and FRR?

- FAR = Unauthorized user accepted (security problem).
- FRR = Legitimate user rejected (usability problem).

If you can explain these examples in your own words, you'll be well prepared for most Authentication & Access Control exam questions.

These are the **highest-probability exam topics**. I'll explain each one simply with **definitions, examples, comparisons, and memory tricks**.

1. Three Data States

Data exists in **three states**.

Data State	Meaning	Example	Protection
Data at Rest	Data stored on a device	Hard drive, database, USB	Encryption (BitLocker, FileVault, LUKS)
Data in Transit	Data moving across a network	Sending email, browsing HTTPS	TLS, VPN, SSH
Data in Use	Data currently being processed	Open Word document, running application	Secure enclaves, Confidential Computing

A. Data at Rest

Definition

Stored data that is **not moving**.

Examples

- Database
- SSD/HDD
- USB flash drive
- Cloud storage
- Backup

Threats

- Stolen laptop
- Stolen USB
- Unauthorized database access

Protection

- Full Disk Encryption (BitLocker)
 - Database Encryption
 - Cloud Encryption
-

B. Data in Transit

Definition

Data traveling over a network.

Examples

- Email
- HTTPS website
- Video call
- File transfer

Threats

- Packet sniffing
- Man-in-the-Middle (MitM)
- Session hijacking

Protection

- TLS (HTTPS)
- VPN
- SSH

- SFTP
-

C. Data in Use

Definition

Data currently being processed in RAM or CPU.

Examples

- Editing a document
- Banking app open
- Running a program

Threats

- RAM scraping
- Malware
- Process injection

Protection

- Confidential Computing
 - Secure Enclaves
 - Hardware security features
-

Easy Memory

Rest → Stored

Transit → Traveling

Use → Processing

2. Symmetric vs Asymmetric Encryption

Symmetric Encryption

Uses **one key**.

Same key encrypts and decrypts.

Example

Alice and Bob both know one secret key.

Alice encrypts.

Bob decrypts using the same key.

Algorithms

- AES □
- ChaCha20

Advantages

- Very fast
- Best for large amounts of data

Disadvantages

- Hard to share the secret key securely

Asymmetric Encryption

Uses **two keys**.

- Public Key
- Private Key

Public Key encrypts.

Private Key decrypts.

Algorithms

- RSA
- ECC
- Diffie-Hellman (key exchange)

Advantages

- Solves the key distribution problem
- Enables digital signatures

Disadvantages

- Much slower than symmetric encryption
-

Easy Example

Symmetric

One house key.

Both people use the same key.

Asymmetric

Mailbox.

Anyone can put a letter in (public key).

Only the owner can open it (private key).

Comparison

Symmetric	Asymmetric
One key	Two keys

Symmetric	Asymmetric
Fast	Slow
AES	RSA, ECC
Bulk data encryption	Key exchange & digital signatures

Exam Question

Why does HTTPS use both?

Answer:

It uses **asymmetric encryption** to exchange a **symmetric session key**, then uses **symmetric encryption** for the rest of the communication because it is much faster.

3. PKI and Digital Certificates

PKI (Public Key Infrastructure)

PKI is the **system that manages digital certificates and public keys**.

It helps users know they are communicating with the correct website or person.

Components

- Certificate Authority (CA)
 - Registration Authority (RA)
 - Certificates
 - CRL/OCSP (certificate status checking)
-

Digital Certificate

A digital certificate is an electronic identity card.

It proves:

- Who owns the public key
- The public key itself
- Who issued the certificate
- Expiration date

Example

When you visit:

<https://google.com>

Your browser checks Google's certificate before creating a secure connection.

Memory Trick

PKI = **Trust System**

Certificate = **Digital ID Card**

4. 3-2-1 Backup Rule

Very common exam question.

Rule

- **3** copies of your data
 - **2** different storage media
 - **1** copy stored off-site
-

Example

Assignment

Copy 1

Laptop

Copy 2

External Hard Drive

Copy 3

Google Drive

Why?

If your laptop fails,
you still have two backups.

Memory

3 Copies

2 Media

1 Off-site

5. DLP (Data Loss Prevention)

Definition

DLP prevents sensitive information from leaving the organization without authorization.

Examples

Blocks employees from:

- Copying files to USB
 - Sending credit card numbers by email
 - Uploading confidential files to cloud storage
-

Types

- Endpoint DLP
 - Network DLP
 - Cloud DLP
-

Example

Employee tries emailing customer credit card numbers.

DLP detects the pattern and blocks the email.

Memory

DLP = Prevent Data Leaks

6. GDPR ("Privacy Regulation with Teeth")

GDPR stands for:

General Data Protection Regulation

It is a European Union privacy law.

Why do people say it has "teeth"?

Because companies can receive **very large fines** if they violate it.

Main Requirements

- Obtain user consent
 - Protect personal data
 - Report certain breaches within **72 hours**
 - Respect the "Right to be Forgotten"
-

Example

A company leaks customer information and fails to report it.

GDPR can impose significant financial penalties.

Memory

GDPR

↓

Privacy Law

↓

Big Fines

7. SSO (Single Sign-On)

Definition

Log in **once**.

Access many applications.

Example

You log into Microsoft once.

Then you can use:

- Outlook
- Teams
- OneDrive

Without logging in again.

Benefits

Users

- One password
- Faster login
- Better user experience

Organization

- Better security
- Easier policy enforcement
- Centralized identity management

IT Team

- Fewer password reset requests
 - Easier account management
 - Faster onboarding and offboarding
-

Risk

If the SSO account is compromised,

many connected services may also be affected.

Protect the Identity Provider (IdP) with strong MFA.

8. Least Privilege (PoLP)

Definition

Give users **only the permissions they need** to perform their jobs.

Nothing more.

Example

Receptionist

Can schedule appointments.

Cannot access payroll.

Benefits

- Smaller attack surface
 - Reduced damage if an account is compromised
 - Prevents accidental changes
 - Improves compliance
 - Limits insider threats
-

Memory

Minimum Access = Maximum Security

9. Zero Trust

Definition

Never Trust, Always Verify

No user or device is trusted automatically—even if it's inside the organization's network.

Three Principles

1. Verify Explicitly
 2. Use Least Privilege
 3. Assume Breach
-

Example

Employee already logged in.

Moves to another sensitive system.

Zero Trust asks for verification again before granting access.

Memory

Never Trust

Always Verify

10. DAC vs MAC vs RBAC vs ABAC

Model	Who Decides?	Example
DAC	Owner	You share your own Google Drive file
MAC	System	Military "Top Secret" access
RBAC	Job Role	Doctor, Nurse, Receptionist
ABAC	Attributes	Allow access only if department = HR, location = Office, and time = Business Hours

DAC (Discretionary Access Control)

Owner controls permissions.

Example

You own a file.

You decide who can read it.

MAC (Mandatory Access Control)

System decides permissions using security labels.

Example

Military.

Top Secret.

Secret.

Confidential.

Users cannot change these permissions.

RBAC (Role-Based Access Control)

Permissions based on job role.

Example

Doctor

↓

Medical records

Receptionist

↓

Appointments only

Most common in companies.

ABAC (Attribute-Based Access Control)

Permissions depend on attributes.

Examples

- Department
- Location
- Time
- Device health

Rule:

Department = Finance

AND

Location = Office

AND

Time = Business Hours

Then

Access Allowed.

Used heavily in Zero Trust.

Memory

DAC

↓

Owner decides

MAC

↓

System decides

RBAC

↓

Role decides

ABAC

↓

Attributes decide

11. MFA Attack Methods

Even MFA can be attacked.

SIM Swapping

Attacker tricks the phone company into moving your phone number to their SIM card.

They receive your SMS codes.

MFA Fatigue (Push Bombing)

Attacker sends many login requests.

Victim keeps getting approval notifications.

Eventually clicks **Approve** out of annoyance.

Real-Time Phishing (Adversary-in-the-Middle)

Attacker creates a fake login page.

Victim enters:

- Username
- Password
- MFA code

Attacker immediately uses them to log into the real website before the code expires.

Protection

- Hardware security keys (FIDO2/WebAuthn)
 - Number matching for push notifications
 - User awareness
 - Phishing-resistant MFA
-

12. IdP (Identity Provider)

Definition

An **Identity Provider (IdP)** is the service that **authenticates users** and confirms their identity.

It tells other applications:

"Yes, this user is legitimate."

Examples

- Microsoft Entra ID (formerly Azure AD)
- Okta
- Google Identity

How It Works



The applications trust the IdP instead of asking you to log in separately.

Quick Revision Table

Topic	One-Line Memory
Data at Rest	Stored data
Data in Transit	Moving data
Data in Use	Processing data
Symmetric	One key, fast (AES)

Topic	One-Line Memory
Asymmetric	Public/Private keys, slower (RSA/ECC)
PKI	Trust system for certificates
Digital Certificate	Digital ID card
3-2-1 Backup	3 copies, 2 media, 1 off-site
DLP	Prevents data leaks
GDPR	Privacy law with strict penalties
SSO	One login for many apps
Least Privilege	Give only necessary access
Zero Trust	Never Trust, Always Verify
DAC	Owner decides
MAC	System decides
RBAC	Role decides
ABAC	Attributes decide
SIM Swapping	Steal SMS MFA codes
MFA Fatigue	Spam push approvals
Real-Time Phishing	Steal credentials and MFA in real time
IdP	Authenticates users for SSO